SOP - SECURITY VERIFICATION AND VALIDATION

[CONFIDENTIAL]
[UTTHUNGA]
[IndiQube, South Summit, South End Rd, Vijayarangam Layout, Bengaluru, Karnataka 560004]

Contents

1 Purpose 3
2 Scope 3
3 Abbreviations 3
4 Terms and Definitions 3
5 Responsibilities 4
6 RACI 4
7 SIPOC 5
8 Overall Process Flow Chart 6
9 Process Description 6
10 Information Security requirements 14
11 References 14
12 Metrics 14
13 Annexures 14
14 Forms 14

CHANGE HISTORY

This section describes the details of changes that have resulted in the current document.

SL. No.	Document Version No.	Change Description	Reason For change	Date Prepared By	Date Reviewed By	Date Approved By
01	0.1	Draft		Anitha N 20-05-24		
02	Issue B, V1.0	New process Implementation			Santosh V 24-05-24	Santosh V 24-05-24
03	Issue B, V1.1	1. Updated Section 14 2. Document formatting done as per document guidelines	Provided relevant links for forms related to SOP	Vanavee P 09-Dec-24	Anitha N 09-12-24	Santosh V 10-12-24
04	Issue C Version 1.0	Review of document	New version update of IMS	Anitha N 01-Aug-25	Santosh V 08-Aug-25	Sanmangala MS 14-Aug-25

1 Purpose

This document establishes a systematic approach for verifying and validating the security aspects of software systems. It ensures that security controls are correctly implemented, and that the software meets its intended security requirements as per IEC 62443.

2 Scope

This SOP applies to all software development projects within Utthunga. It covers both custom-developed software and third-party application.

3 Abbreviations

a. SVV: Security Verification and Validation

b. IEC: International Electrotechnical Commission

c. ISVV: Information Security Verification and Validation

d. JLPT: Japanese Language Proficiency Test

e. SOP: Standard Operating Procedure

f. IMS: Integrated Management System

g. CSRF: Cross-Site Request Forgery

h. SAST: Static Application Security Testing

4 Terms and Definitions

a. Security Requirements Testing (SVV-1): Ensures the defined security requirements are fulfilled and the product handles error scenarios and invalid input correctly.

b. Threat Mitigation Testing (SVV-2): Ensures the defined mitigations based on the threat model are working as intended. Vulnerability Testing (SVV-3): Identifies and characterizes potential security vulnerabilities in the product.

c. Penetration Testing (SVV-4): Tests performed to breach the system and find unknown weaknesses or confirm the exploitability of known vulnerabilities.

d. None: Tester can be part of the development team.

e. Independent Person: Tester cannot be part of the development team.

f. Independent Department: Tester cannot report to the same first-line manager as the product development team.

g. Independent Organization: Tester cannot be part of the same legal organization.

5 Responsibilities

a. Project Manager: Ensures the security verification and validation process is planned and executed correctly.

b. Independent Department: Conducts security tests to ensure unbiased results.

c. Development Team: Implements security requirements and mitigations, and addresses any identified issues.

d. Security Engineer: Coordinates and oversees the penetration testing, analyzes the findings, and ensures proper documentation.

6 RACI

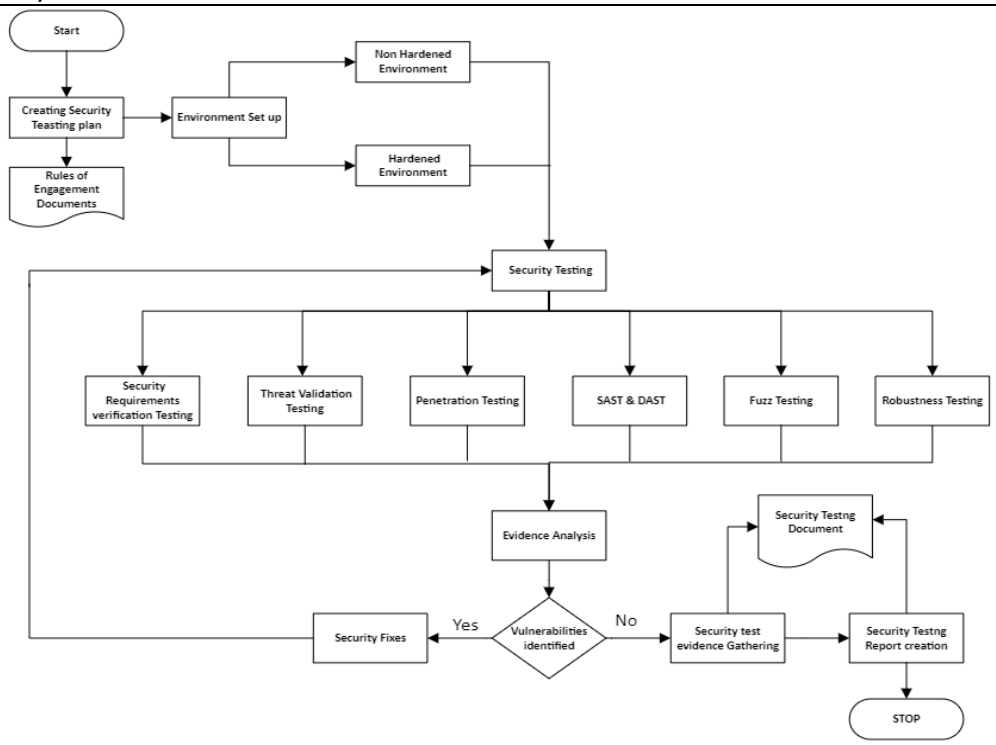
Process	Responsible	Accountable	Consulted	Informed
Security Requirements Testing (SVV-1)	Tester from Independent Dept	Project Manager	Security Engineer	Development Team
Threat Mitigation Testing (SVV-2)	Tester from Independent Dept	Project Manager	Security Engineer	Development Team
Vulnerability Testing (SVV-3)	Independent Tester	Project Manager	Security Engineer	Development Team
Penetration Testing (SVV-4)	Tester from Independent dept. or Org	Security Engineer	Project Manager	Development Team

7 SIPOC

Supplier	Input	Process and Control		Output	Customer
		Process	Control		
Standards Bodies, Development Team, Independent department	IEC 62443-4-1 Requirements, Product specification, Test tools, Test Plans	Security Requirements Testing (SVV-1)	Test plans and checklists, test execution guidelines	Security Requirements Test Report	Project Manager
Standards Bodies, Development Team, Independent department	IEC 62443-4-1 Requirements, Product specification, Threat model, Test tools, Test Plans	Threat Mitigation Testing (SVV-2)	Test plans and checklists, mitigation verification guidelines	Threat Mitigation Test Report	Project Manager
Standards Bodies, Development Team, Independent department	IEC 62443-4-1 Requirements, Product specification, Test tools, Test Plans	Vulnerability Testing (SVV-3)	Test techniques and tools guidelines, vulnerability assessment criteria	Vulnerability Test Report	Project Manager
Standards Bodies, Development Team, Independent department	IEC 62443-4-1 Requirements, Test tools, Test Plans, Expertise, Product Specification	Penetration Testing (SVV-4)	Penetration test environment setup, test execution guidelines, severity rating criteria	Penetration Test Report	Security Engineer

8 Overall Process Flow Chart

a) Security Verification and Validation Process



9 Process Description

As per ISVV-1, SVV-2, SVV-3, SVV- 4, SVV-5 of IEC 62443-4-1 requirements, security testing and verification strategy shall ensure the correctness of products. To minimize bias during the security tests, different independence levels shall be adapted. The different levels are described in the following table as per SVV5

Dependence	Explanation
None	The tester doesn't need any independence from the development team. The developer can, for instance, perform the testing.
Independent person	The tester cannot be part of the development team of the product.

Independent department	The tester cannot report to the same first-line manager as any individual on the product development team.
Independent organization	The tester cannot be part of the same legal organization.

9.1 Security Requirements Testing (SVV-1)

a. To ensure that the defined security requirements (Specifying Security Requirements) are fulfilled and the product handles error scenarios and invalid input correctly, Project team shall have an independent department perform appropriate security tests. At least the following types of testing must be performed:

- Functionality testing of the security requirements.
- Performance, and scalability testing
- Boundary/edge cases, stress, and malformed or unexpected input testing

b. If the tests can be automated (e.g., unit tests), have the implementation and the completeness of the tests reviewed by an independent department that also ensures the correct execution of the tests after each product change.

c. One of the mandatory acceptance criteria per security requirement is to have different security tests defined.

Example

Example 1: Security Requirement: All failed login attempts are logged.

The following tests could be performed:

- Provide an existing username and correct password.

Check that no failed login attempt is logged.

[functionality]

- Provide a non-existing username and the password of an existing user.

Check that a failed login attempt is logged.

[functionality]

- Provide the username of an existing user and an incorrect password.

Check that a failed login attempt is logged.

[functionality]

- Provide the username of an existing user and an empty password.

Check that a failed login attempt is logged.

[functionality, edge-case]

- Provide the username of an existing user and an invalid password that contains a ✋ emoji. Check that a failed login attempt is logged.

Provide a non-existing username and the password of an existing user. Check that a failed login attempt is logged.

[functionality]

- Provide the username of an existing user and an incorrect password.

Check that a failed login attempt is logged.

[functionality]

- Provide the username of an existing user and an empty password.

Check that a failed login attempt is logged.

[functionality, edge-case]

- Provide the username of an existing user and an invalid password that contains a ✋ emoji. Check that a failed login attempt is logged.

[functionality, edge-case]

- Send 10'000 login attempts with an existing username and an incorrect password at the same time.

Check that 10'000 failed login attempts are logged and that the response time did not exceed 1 second.

[scalability, performance]

- Send 10'000 login attempts with an existing username and an incorrect password, and 1

Provide the username of an existing user and an invalid password that contains a ✋ emoji. Check that a failed login attempt is logged.

[functionality, edge-case]

- Send 10'000 login attempts with an existing username and an incorrect password at the same time.

+ Check that 10'000 failed login attempts are logged and that the response time did not exceed 1 second.

[scalability, performance]

- Send 10'000 login attempts with an existing username and an incorrect password, and 1 request with the same username, but the correct password.

Check that 10'000 failed login attempts are logged and that the response time did not exceed 1 second.

[scalability, performance]

9.2 Threat Mitigation Testing (SVV-2)

a. To Ensure that the mitigations that have been defined based on the threat model are working as intended, Project team shall have an independent department test the effectiveness of the mitigation.

b. create or expand the existing test plan. The plan must ensure that each mitigation is tested adequately and works as designed. Furthermore, the test plan must include tests that try to bypass and thwart the mitigations. Once the mitigations are implemented and the test plan is defined, ensure that the test plan is executed correctly. Note that it is essential that the test results are reported and documented. A threat mitigation report template can be used which is available in IMS

c. For each failed test, handle it as per Managing Security Issues process under Address Security Issues. capture all the failed test tested again until they are resolved. Make sure that all documents are archived.

Example

The development team receives a report that indicates, which tests were performed and sees if they succeeded, such as the following excerpt.

Mitigation 9: Authenticate users to prevent arbitrary users from changing the settings.

ID	Test	Additional Information	Result
9.1	Send requests to change the pressure setting as an unauthenticated user.		✓
9.2	Once a user logs out, the user can no longer change the settings.		✓
9.3	The authenticated settings change cannot be initiated with a CSRF.		✓

9.3 Vulnerability Testing (SVV-3)

a. To identify and characterize potential security vulnerabilities in the product, perform all applicable security testing techniques listed in the following table. If the test technique is automated, the test should be triggered on code changes and periodically if no code changes happen for a while. Furthermore, ensure that this test concept is followed when testing the product and that the test responsible has the required knowledge and education to efficiently apply the techniques.

Test Technique	Objective	Examples and tools
Abuse cases or malformed or unexpected Test external interfaces and protocols input testing	Test External interfaces and protocols manually or automatically with specifically crafted abuse cases.	Fuzz testing: afl++ RESTler Network traffic load testing: Nping
Attack surface analysis	Determining all avenues of ingress and egress to and from the system, common vulnerabilities like weak ACLs, exposed ports, and services running with elevated privileges	Port Scanning: nmap MASSCAN
Black box known vulnerability scanning	Detecting known vulnerabilities in the product hardware, host, or software components.	Network Scan: • Nessus • Nuclei Website Scan: • . Nikto
Software component analysis	Detection of known vulnerabilities in used software. Binary	Software dependencies: • Mend • Snyk

	executables like firmware images. The following information should be gathered by the solution at a minimum: 1. known vulnerabilities in the product software components 2. a linking to the vulnerable libraries 3. security rule violations 4. used compiler settings that can lead to vulnerabilities	Tech stack on machines • Dynatrace Binaries, Firmware: • Black Duck SCA
Dynamic runtime resource management testing	Detection of flaws not visible under static code analysis, including but not limited to denial-of-service conditions due to failing to release runtime handles, memory leaks, and accesses made to shared memory without authentication.	Web Site/APIs: ZAP, Burp, ... Binaries: Valgrind, LLVM address sanitizer
Static Source Code Scans	Detect patterns that introduce common security issues.	SAST: • SonarQube • Snyk Code • PC-Lint

b. All findings identified during testing process with the above-mentioned techniques must be analyzed for validity and security impact. If the finding is invalid, i.e., a false positive, document the reason for false positive.

c. If the finding is valid and security-relevant, the Managing Security Issues process must be followed. Otherwise, the project-specific defect management process can be used as per the defect management process available in IMS.

9.4 Penetration Testing (+ SVV-4)

a. Depending on the intended security level, project manager shall plan a penetration test by an independent department or even an independent organization with the necessary expertise.

b. penetration test shall be performed before the go-live or whenever major changes to the product are implemented. In the latter case, the penetration test can focus on the components that changed, but this must be clearly documented and motivated.

c. The goal of the penetration test is to breach the system of the product and find unknown weaknesses, but also to confirm and assess the exploitability of accepted vulnerabilities and the defense-in-depth strategy.

d. When having a penetration test conducted the following requirements must be followed:
   - The test environment must be realistic and can be based on scenarios in the threat model. All assumptions related to the test environment should be documented. Especially, if attacks are simulated in which the attacker already has a set of initial permissions.
   - The penetration test must be conducted by security professionals.
   - If components are excluded from the penetration test, it must be documented why and signed off by the project owner and the security engineer.
   - The duration of the penetration test must be negotiated between the security engineer and the independent party, in particular, the product's complexity and security level must be taken into
   - Independent party, in particular, the product's complexity and security level must be considered for this discussion.

e. The penetration test must result in a report that describes all security findings. The findings should be rated by severity by the independent party.

f. After receiving the report, analyze the findings according to Managing Security Issues process under Analyze Security Issues. If a finding is rated as high or above by the independent party but lowered by the internal analysis, clearly document, and justify the adjustment to the finding rating.

10 Information Security requirements

a. Testing of security functionality shall be carried out during development.
b. Acceptance testing programs and related criteria shall be established for new information systems, upgrades, and new versions.
c. Test data shall be selected carefully, protected, and controlled.
d. Confidentiality of data is maintained.

11 References

a. SOP-Testing Validation and Acceptance (TVA)-UTSDTVASOP.pdf

12 Metrics

a. Test Coverage: Percentage of security requirements covered by tests.
b. Defect Density: Number of security issues identified per module.
c. Mean Time to Remediate (MTTR): Average time taken to fix identified security issues.
d. Test Automation Rate: Percentage of tests that are automated.
e. Severity of Findings: Distribution of identified issues by severity level (high, medium, low).

13 Annexures

a. Security Requirement Testing Details (SVV-1)
b. Threat Mitigation Test Plan Template (SVV-2)
c. Vulnerability Testing Techniques and Tools (SVV-3)
d. Penetration Test Plan and Report Template (SVV-4)

14 Forms

a. 1. SDL Security Verification Checklist UTSDTVATMP01.xlsx

b. 10. Penetration Testing Report Template UTSDTVATMP10.docx

c. 12. Project Penetration Test Plan & Observations Template UTSDTVATMP12.xlsx

d. 13. Project Threat Validation Test Plan & Observations Template UTSDTVATMP13.xlsx

e. 14. Security checklist - UTSDTVATMP14.xlsx

f. 2. SDL Test Plan Review Checklist UTSDTVATMP02.xlsx

g. 3. SDL Test Plan Template UTSDTVATMP03.docx